



SPRINT No 2 REVIEW

Entrega 4 · Sprint 2 Review / Planning Sprint 3

SPRINT GOAL

Demostrar, sobre un esqueleto vertical en DEV y QA, que cliente y aliado se registran, declaran cobertura y categoría, y que una solicitud se asigna a un único aliado — con las decisiones críticas validadas por PoC y documentadas en SDD, SAD e Infraestructura.



Agenda

01

Negocio

Qué hace MANI hoy · qué está garantizado · riesgo abierto · costo · qué sigue

02

Arquitectura y evidencia

SRS, SAD, SDD, DD e Infraestructura · PoC y pruebas · seguridad · normativa · Mesa

03

Review

Entregables · Backlog · métricas de Jira · propuesta de Sprint 3



Qué contiene la Entrega 4

Documento	Versión	Qué cambia
SRS	V3	Evidencia de PoC en los RNF, autorización por rol, listado paginado, IdP resuelto
Product Backlog	V3	Historias EP-01, estado real, criterios Gherkin, PoC, deuda, Sprint 3
SAD	V3	KI-12/KI-13, ADR-0025...0029, QS-21/22, Tabla E, 4+1 ↔ C4, vista física
SDD	V1 (nuevo)	4+1 con C4, API Gateway, alcance de Java y .NET, validación
DD	V2	Reparto por servicio, migraciones 001–010, RLS con rol, KYC corregido, glosario
Infraestructura	V1 (nuevo)	DEV/QA/PROD, seguridad por capas, secretos, Kubernetes
Herramientas y políticas	V3	Sin Azure, Railway + GHCR, Tech Radar V3, DoR/DoD, políticas
Informes	—	Inf_PoC-001 · Inf_test-001 · Inf_test-002

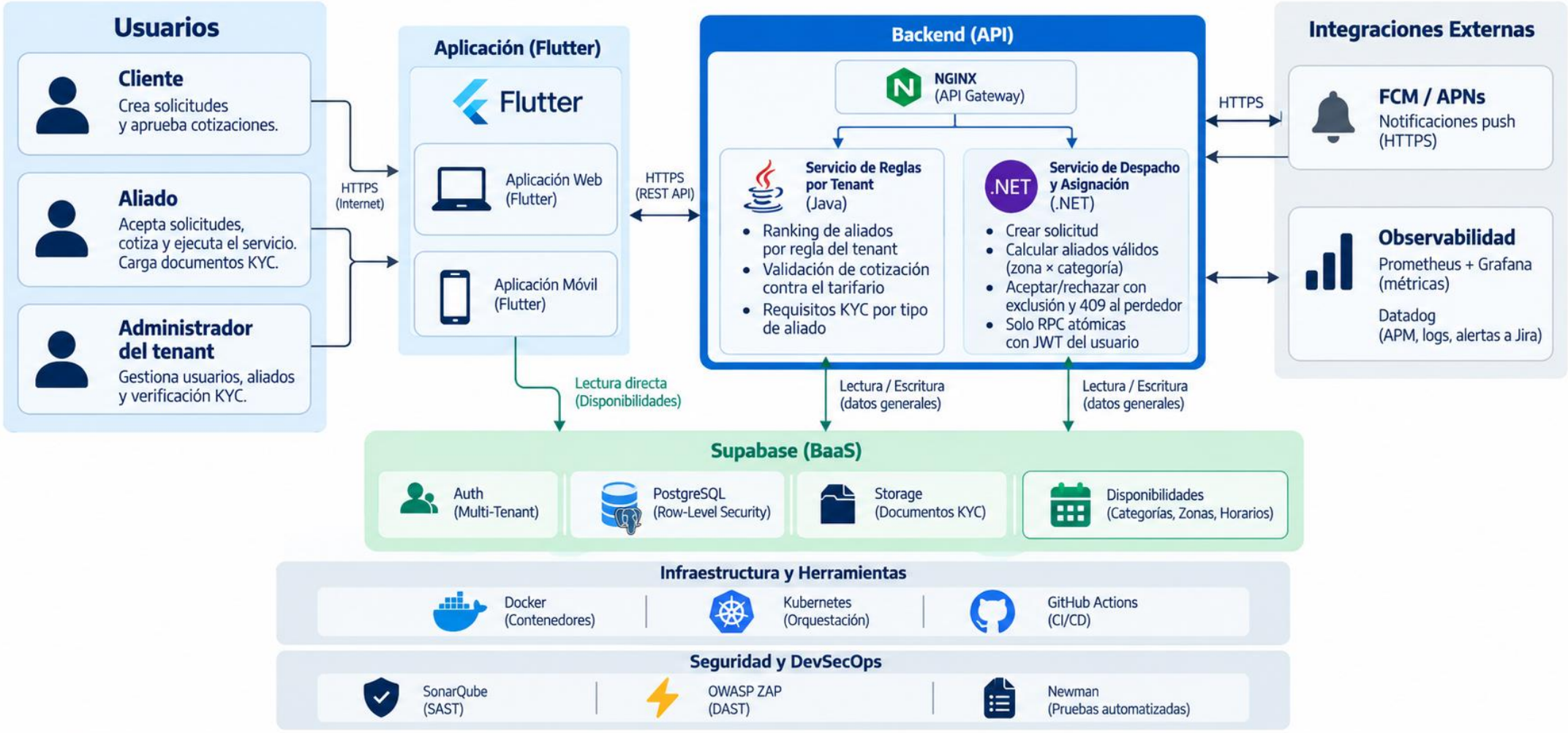


Negocio

Qué puede hacer MANI hoy, qué está garantizado y qué riesgo sigue abierto.

Para contexto

Diagrama de Alto Nivel – MANI



■ Qué puede hacer MANI hoy

- Técnicos (personas o empresas) y clientes **se registran**
- La empresa **aprueba o rechaza** a cada técnico
- El técnico elige **en qué zonas y en qué servicios** trabaja
- El cliente **publica una solicitud** con fotos
- **Un solo técnico** se queda con cada solicitud

Funciona en el ambiente de pruebas. Todavía no está en producción.

9

funcionalidades listas para probar

60

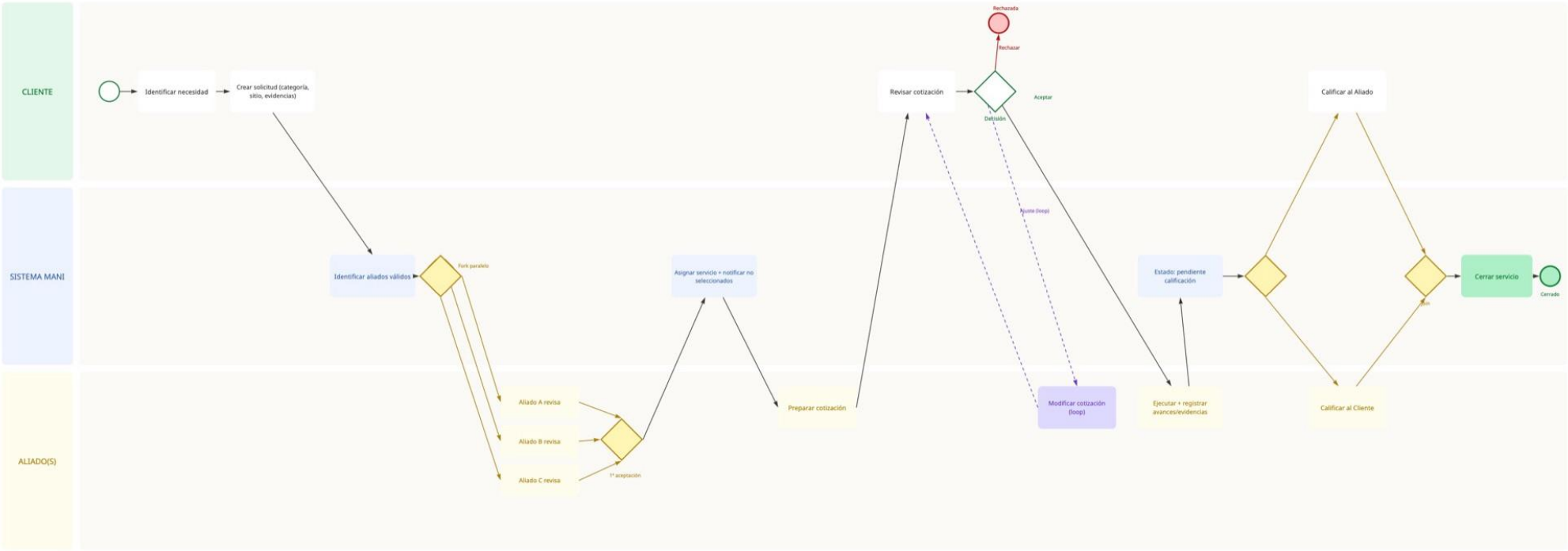
funcionalidades en el plan total

El resto del ciclo (cotizar, ejecutar, calificar y pagar) está en el plan de los próximos sprints.

El ciclo del servicio que habilita MANI

BPMN: Ciclo Completo del Servicio

Broadcast concurrente, loop de ajuste, calificaciones paralelas



BPMN · Ciclo completo del servicio (Diagramas/Negocio/v1). Broadcast concurrente, ajuste de cotización, calificaciones paralelas.

Cuánto cuesta operarlo

Recurso	DEV	QA	PROD
Base de datos	Docker local	Supabase Free	Supabase Pro · \$25
Cómputo	Máquina local	—	\$0
CI/CD	Local	Actions Free	Actions Free
Storage	Local	Free	Incluido
Dominio + TLS	localhost	—	~\$2

~\$27

USD al mes de operación

Frente a \$200–300/mes de un clúster gestionado + RDS (Infra V1 \$15).



Arquitectura y evidencia

Diseño, pruebas, seguridad y normativa de la Entrega 4.

SRS V3 — Qué cambió

- **RNF-01** ahora exige autorización **por rol** dentro del tenant (hallazgo H-02)
- **RF-12** exige listado **paginado** (PoC-004 H-03)
- Evidencia de PoC en **RNF-01, 03, 05 y 07**
- Proveedor de identidad resuelto: **Supabase Auth** (ADR-0022)
- Nueva suposición **SUP-06**: un usuario pertenece a un solo tenant

Notas de consistencia

- N-01 Kubernetes: el "sí" está resuelto; el "dónde" es propuesta (ADR-0029)
- N-02 KI-02 cerrado por ADR-0023
- N-03 Numeración ADR-0021/0023 en ratificación
- N-04 Borradores reenumerados a 0027/0028

SAD V3 — Qué agrega

- Resultados de **PoC-002, 003 y 004** en killers, ADR y escenarios
- Killers nuevos **KI-12 y KI-13**
- ADR-0025/0026 (DoD/DoR) y borradores **ADR-0027/0028/0029**
- Escenarios **QS-21** (modularidad) y **QS-22** (portabilidad)
- **Tabla E** de evidencia · vistas **4+1 ↔ C4** · **vista física**

26

ADR en la carpeta

18

Aceptados / Aprobados

8

Propuestos

3

borradores (0027–0029)

SAD V3 — Killers nuevos

KI-12 · RLS sin versionar. Las 16 políticas `tenant_isolation_*` existen solo en QA. Reconstruir un ambiente desde las migraciones lo dejaría sin aislamiento. **Bloquea aprovisionar PROD.**

KI-13 · RLS sin rol. `tenant_isolation_solicitud` tiene `roles = {public}`: un cliente puede autoasignarse una solicitud de su propio tenant.

Mitigación propuesta: migración 008 con políticas por rol (DD V2 §8.1) + chequeo de rol en la RPC `aceptar_solicitud` · SP-TO-06 prioridad 1 · SCRUM-1051, SCRUM-1052



SAD V3 — Escenarios validados

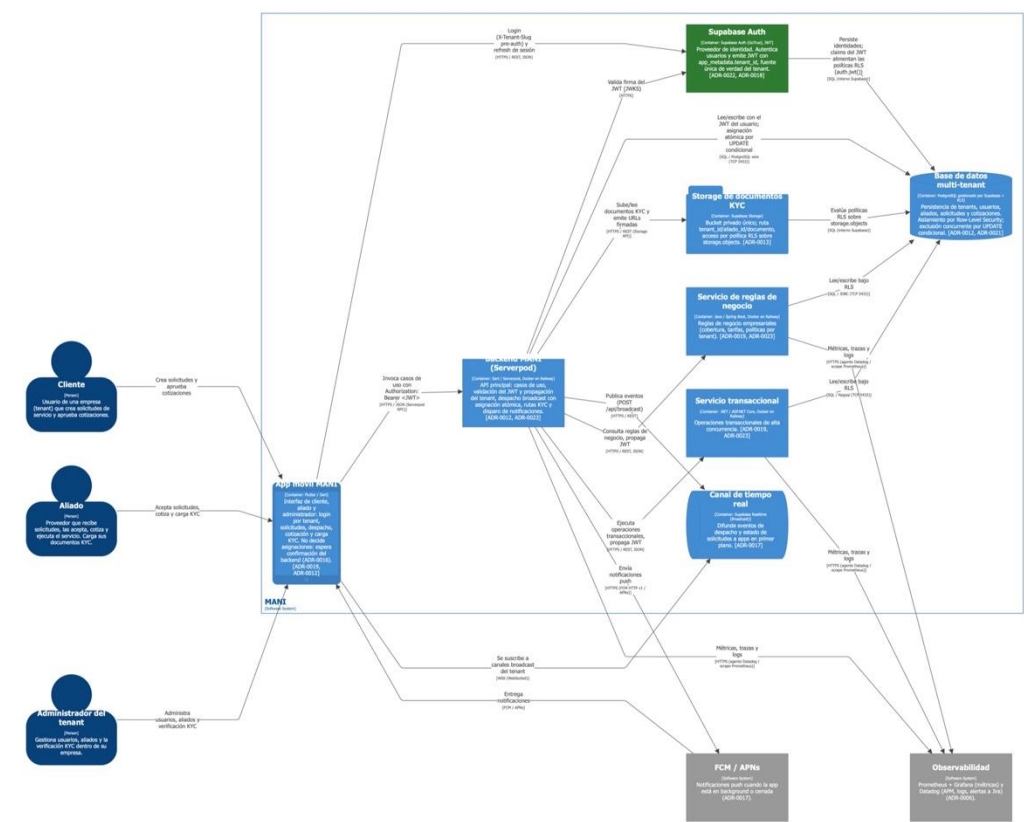
Escenario	Validado por	Resultado
QS-02 Aislamiento entre tenants	PoC-002 · Inf_test-002	0 fugas · 4/4 suplantaciones · 135/135
QS-04 KYC aislado	PoC-003	95/95 · tiempo de bandeja sin medir
QS-08 Listado < 1 s con 20 usuarios	PoC-004	296 ms E2E · BD 9,48 ms solo con 2 índices
QS-09 Exactamente 1 asignación	PoC-001	1 de 50 · control negativo: 10
QS-11 Idempotencia	PoC-001 r5	Reintento → 200, 0 filas nuevas
QS-17 Suite bloquea el merge	—	Existe y pasa; no corre en cada PR

Nuevos: QS-21 Modularidad (≤ 50 ms por salto de servicio) y QS-22 Portabilidad (cambio de IdP sin tocar RLS). Pendientes de aceptación.

SDD V1 — Diagramas

Vista 4+1	Se dibuja con
Escenarios (+1)	QS-01...22 + BPMN
Lógica	C4 L1 + L2 · dominio · MER
Procesos	Secuencias UML
Desarrollo	C4 L3 · repos · Clean Arch.
Física	C4 Deployment → Infra V1

ADR-0024: 4+1 define qué vistas; C4, UML, BPMN y MER definen cómo. Fuente única: workspace-as-built.dsl



C4 Nivel 2 · Contenedores (Diagramas/c4/C2-Contenedores.png)

SDD V1 — API Gateway

Opción	A favor	En contra	Resultado
Spring Cloud Gateway	Libre · valida JWT contra JWKS · equipo sabe Java	Memoria de la JVM	Elegida
YARP (.NET)	Libre, rápido	Menos experiencia	Alternativa válida
KrakenD CE	Declarativo, liviano	Rutas comodín solo Enterprise	Descartada
Kong OSS	Maduro	JWKS solo Enterprise	Descartada
Nginx	Ya sirve la SPA	Sin JWT ni rate limit por claim	Descartada
Sin gateway	Cero piezas	Flutter acoplado a 3 URLs	Descartada

Hace: enrutar, validar el JWT temprano, CORS, rate limit por tenant, trazas W3C. No hace: lógica de negocio ni confiar en cabeceras de tenant.

SDD V1 — Alcance de Java y .NET

Java • Motor de Reglas por Tenant

- Ranking de aliados según la regla del tenant (RF-13)
- Validar cotización contra el tarifario (RF-16)
- Requisitos KYC por tipo de aliado (RF-05)
- Sin base propia: lee la configuración del Core

.NET • Motor de Despacho y Asignación

- Crear solicitud (RF-12)
- Calcular aliados válidos (zona × categoría)
- Aceptar/rechazar con exclusión y 409 al perdedor (RF-14)
- Solo RPC atómicas con el JWT del usuario

Criterio: cada módulo tiene responsabilidad real y trazable, no solo cumple PROY-07. El Core (Serverpod) conserva el resto de módulos.



SDD V1 — De dónde estamos a dónde vamos

Hoy	Estado
App Flutter con Clean Architecture	Hecho
Login, registro, cobertura, categorías, solicitud	Hecho
Aceptar/rechazar	Parcial · datos en memoria
Migraciones 001–007 en QA	Hecho
Hook de claims, bucket KYC	Solo en PoC
Core, Java, .NET, Gateway	Por hacer

Plan de migración

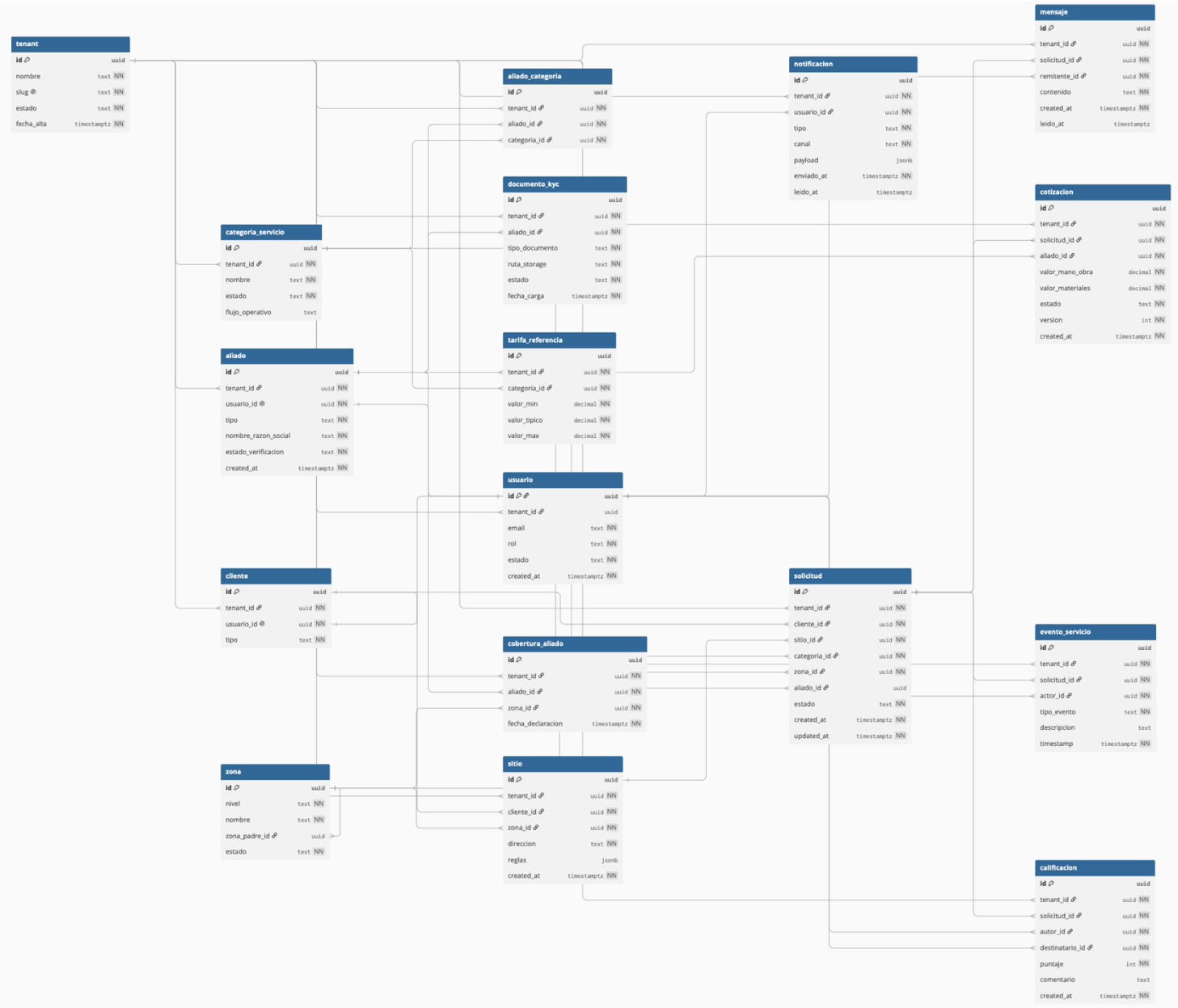
1. Promover PoC a migraciones + RLS con rol + índices
2. Gateway + Core mínimo + cliente HTTP
3. Despacho .NET: la app deja el repositorio en memoria
4. Reglas Java: ranking y cotización
5. Registro y verificación vía Core
6. Realtime, push, observabilidad, K8s

DD V2 - Datos/ migraciones

Migración	Estado
Esquema inicial (17 tablas)	En QA
Verificación de aliados · categorías · aliado-categoría	En QA
Aceptar/rechazar · crear solicitud	En QA
Normalizar dominios a MAYÚSCULA	En QA
RLS tenant_isolation_* con rol	Pendiente
2 índices de cobertura	Pendiente
Promover hook, bucket KYC, RPC	Pendiente

123,91 ms
cobertura a 100k sin índices

9,48 ms
con los 2 índices (umbral 50 ms)



DD V2 — Seguridad: RLS con rol y KYC corregido

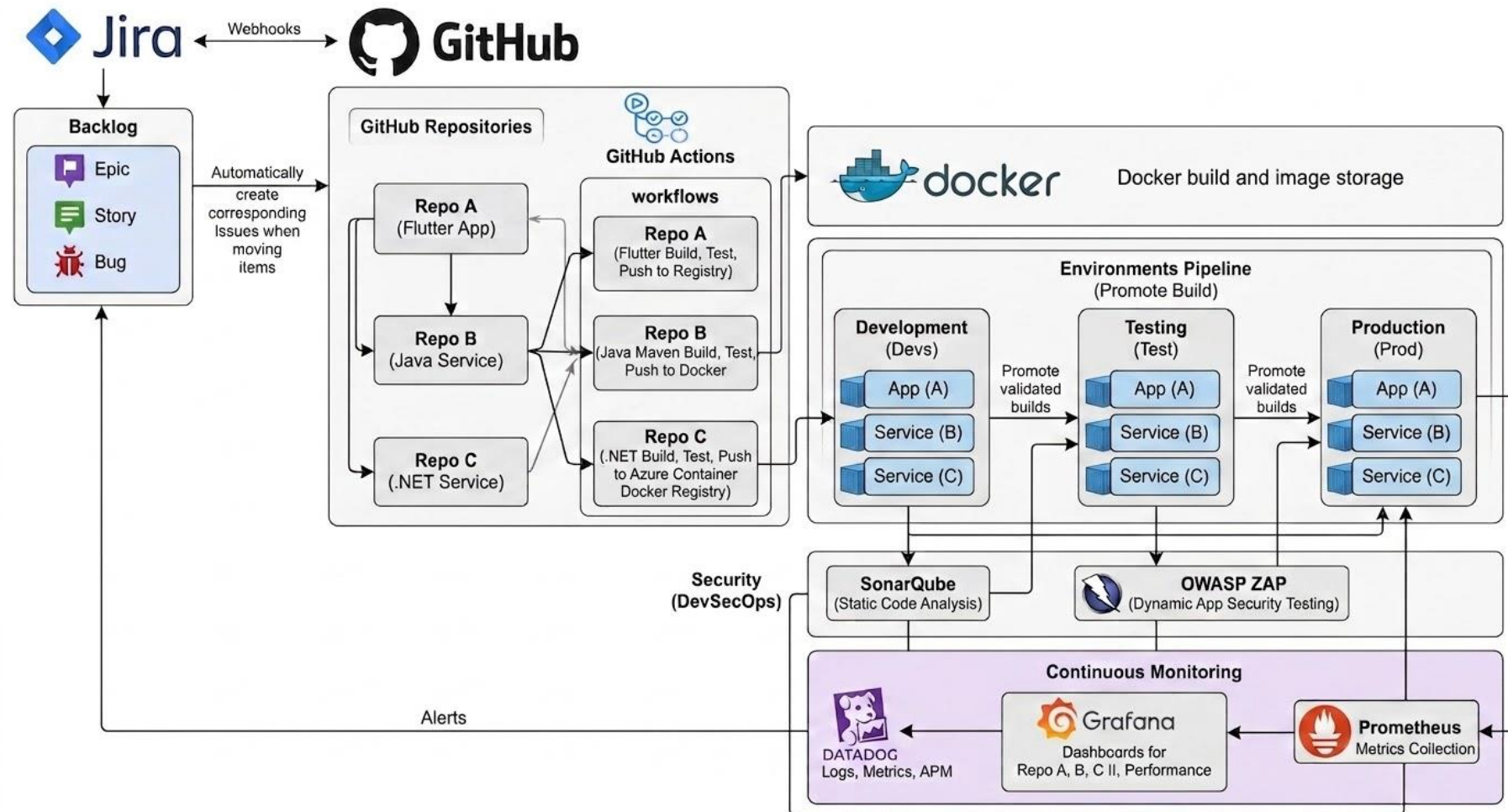
```
-- Patrón V2 propuesto (migración 008)
CREATE POLICY solicitud_insert_cliente
  ON solicitud FOR INSERT TO authenticated
  WITH CHECK (tenant_id = app.tenant_id()
    AND app.user_role() = 'cliente');

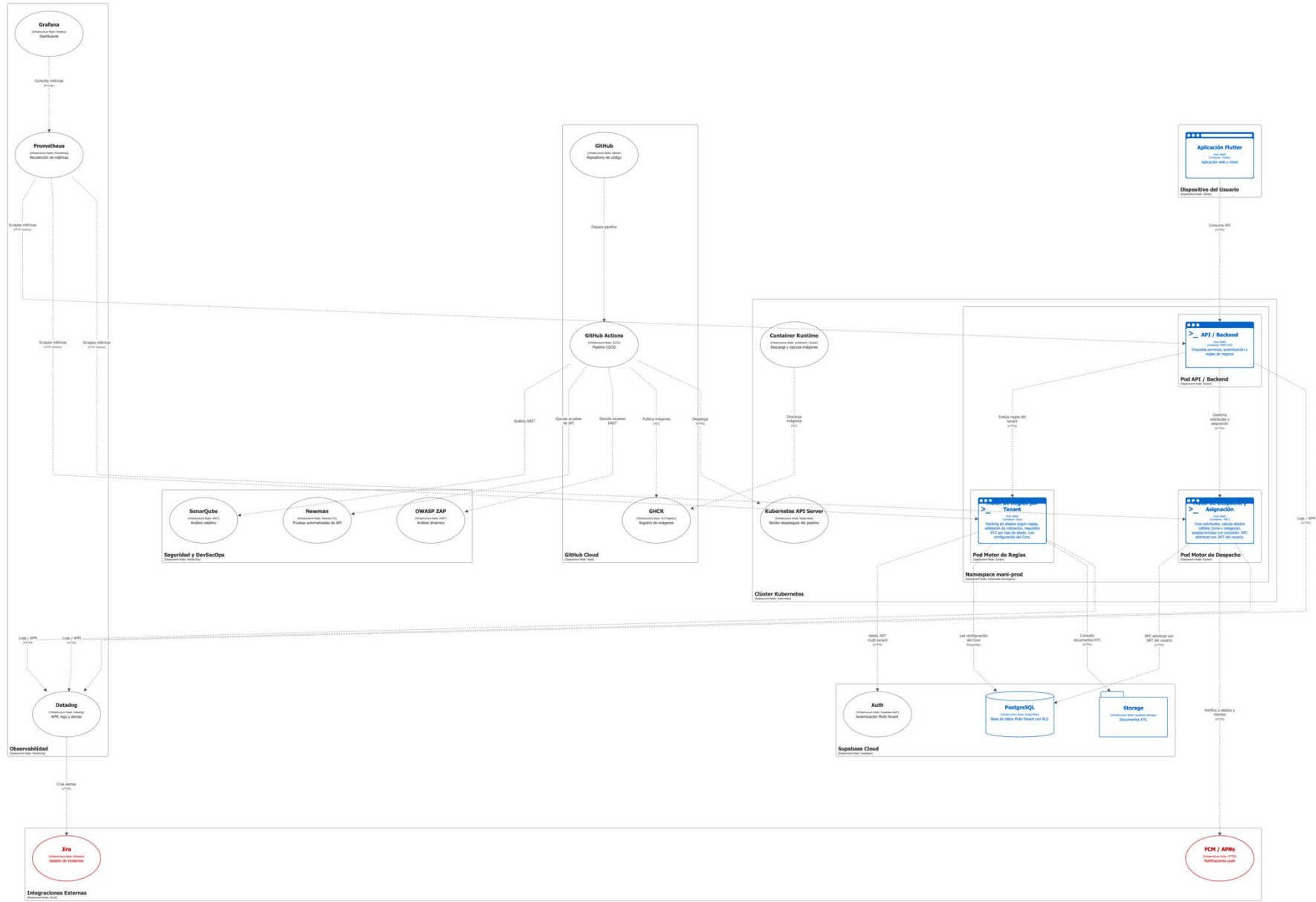
CREATE POLICY solicitud_update_aliado
  ON solicitud FOR UPDATE TO authenticated
  USING (tenant_id = app.tenant_id()
    AND app.user_role() = 'aliado');
```

Hallazgo PoC-003	Corrección
H-01 URL firmada = token al portador	TTL ≤ 60 s · emitida solo por el Core
H-02 aliado_id vs auth.uid()	La ruta usa auth.uid()
H-04 política FOR ALL	Se separa: el admin_tenant solo lee

Control por rol en dos capas: RLS en los datos + middleware en cada servicio.

Infraestructura V1 — Vista de Despliegue

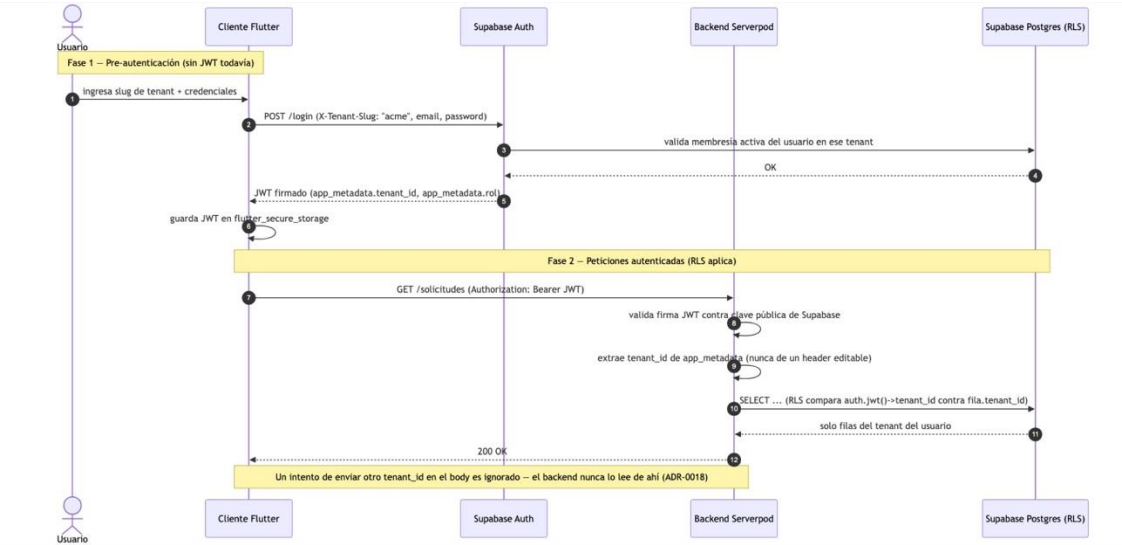




Infraestructura V1 — Seguridad por capas

1 Identidad · JWT ES256 con tenant y rol
2 Borde · gateway valida JWT
3 Servicio · revalida JWT y rol
4 Datos · RLS (KI-12, KI-13)
5 Archivos · bucket privado + URL firmada
6 Entre servicios · token relay
7 Red · TLS · NetworkPolicy
8 Cadena de suministro · Sonar
9 Proceso · rulesets · Environments

Verde: validada · Verde claro: parcial · Gris: por hacer · Ámbar: brecha



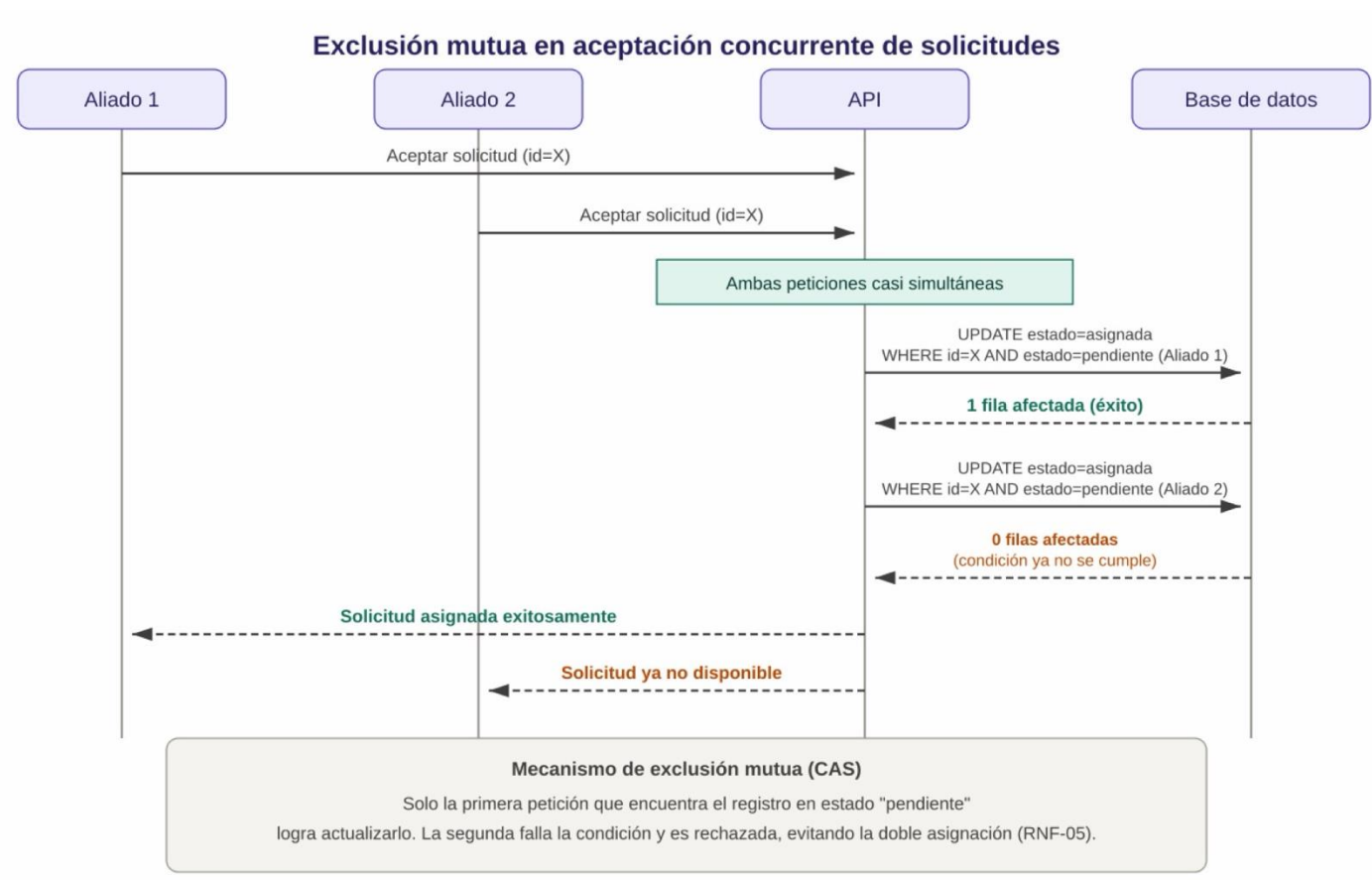
Flujo de autenticación con tenant (Diagramas/Negocio/flujos)

PoC— Las 4 pruebas de concepto

PoC	Pregunta	Resultado	ADR
001 Exclusión concurrente	¿N aceptaciones → 1 asignación?	1 de 50 · 49×409 · control: 10 en 136 ms	0021 → Aceptar
002 Claims de tenant	¿El JWT propaga tenant y rol?	100 % · 0 fugas · 4/4 suplantaciones · ES256 0,10 ms	0018 confirmado
003 Storage KYC	¿Aísla documentos? ¿Cuánto tarda?	1 MB p95 1180 ms · URL 423 ms · 95/95	0013 + 3 correcciones
004 Cobertura	¿zona_id cumple con volumen?	100k: 123,91 → 9,48 ms con 2 índices · E2E 296 ms	0011 confirmado

Protocolo: umbral publicado en Jira antes de medir · control negativo que debe fallar · evidencia cruda versionada · conclusión para el ADR.

PoC— Exclusión mutua en la aceptación



Diagramas/diagrama_secuencia_exclusion_mutua.png · UPDATE ... WHERE estado = pendiente: solo el primero afecta 1 fila

PoC— Benchmarking geográfico

Variante (100k, con índices)	p95 BD	Precisión
zona_id (vigente)	9,48 ms	100 %
PostGIS	7,17 ms	100 %
Bounding box refinado	9,52 ms	100 %
Geohash	8,35 ms	93,78 %

Extremo a extremo (k6, 20 usuarios, 10k): 287–296 ms en las 4 variantes · objetivo QS-08 < 1000 ms.

Conclusión

- Se mantiene el match por **zona_id** (ADR-0011)
- Si algún día se resuelve la zona desde coordenadas: **PostGIS**
- **Geohash descartado**: 6,2 % de error en los bordes
- Deuda: 2 índices (SCRUM-1054)

■ Resultado de Test — Pipeline y promoción a QA

313

pruebas Flutter · 18 de
integración

85,4 %

cobertura de líneas

135/135

asepciones Newman contra
QA

21/21

verificación de la migración
007

Gate técnico: cumple

- Un paso en rojo detiene la cadena (demostrado 2 veces)
- Migraciones 001–007 aplicadas por CI en QA
- Snapshot, simulación y snapshot posterior: coinciden

Gate de proceso: no cumple

- #9 y #14 sin revisión · 8 commits directos
- 8 de 9 historias sin criterios
- Promovido con excepción (SCRUM-1055, 1056)

Herramientas V3 — Tech Radar

Tecnología	V2	V3 propuesto
Azure	Tal vez	Mejor no
Railway	Mejor no	Sí o sí
Kubernetes	Sí o sí (AKS)	Sí o sí, sin AKS
GHCR	—	Sí o sí
Spring Boot / Gateway	Mejor no	Tal vez → Sí o sí*
k6 · Newman	Sí o sí	Sí o sí, usados
Structurizr DSL	—	Sí o sí
Geohash	—	Mejor no

* Si la Mesa ratifica ADR-0027/0028.



Tech Radar V2 (Diagramas/TECH_RADARv2.png) · base de los cambios V3

Herramientas V3 — DoR, DoD y nuevas políticas

DoR · paso a QA (ADR-0026)

- Gherkin aceptado por el PO: positivo, negativo e intento de violar la regla
- Evidencia funcional (captura o video)
- Pruebas trazables a cada criterio
- Aislamiento con 2 tenants · run de CI en verde

DoD · pase a main (ADR-0025)

- Pipelines en verde · Newman, Maestro o k6 según lo que toque
- Regresión manual · Quality Gate · aceptación del PO

Política de PoC

- Umbral publicado antes de medir
- Control negativo obligatorio
- Cada negativo con su espejo positivo
- Terminado = informe mergeado

Política de migraciones

- Nada a mano en Supabase
- Idempotentes (se prueban 2 veces)
- Toda RLS vive en la cadena



Normativa — dónde está y qué falta

Norma	Dónde está en la entrega	Estado
Ley 1581 (Habeas Data)	US-02.3.2 en Backlog V3 · Política de Datos (DOC-22)	Politica propuesta
PCI DSS	SRS V3: REST-03 y RNF-06	Delegado al operador de pagos · 2º incremento · operador sin elegir
OWASP Top 10	ADR-0005 · Herramientas V3 §4.3	SonarCloud solo en main · ZAP sin integrar
ISO/IEC 25010:2023	SAD V3 §4 (AC-01...AC-19)	19 atributos · QS-21 y QS-22 nuevos

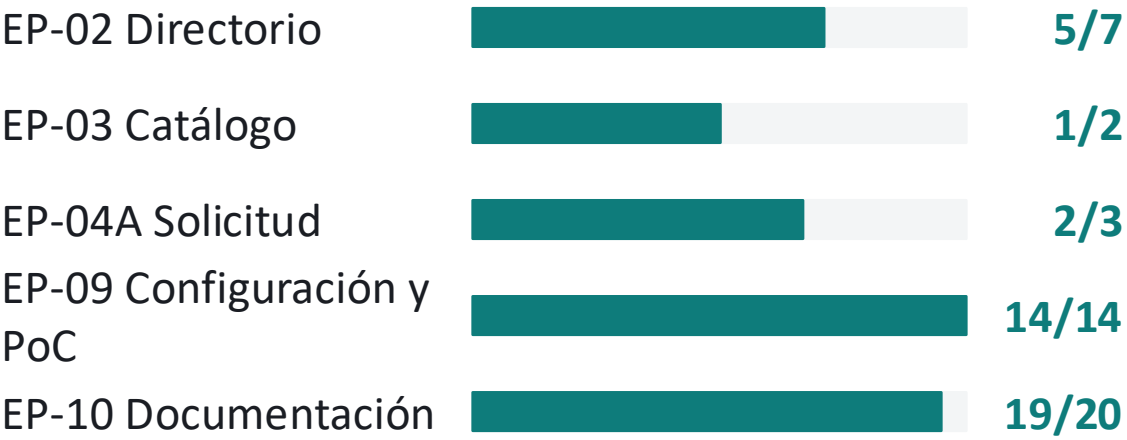
Esta entrega no declara cumplimiento de la Ley 1581 ni de OWASP: queda registrado lo que existe y lo que falta.



Review

Entregables, backlog, métricas del sprint y lo que sigue.

Avance del sprint



Issues cerrados sobre issues del sprint, por épica. Sin cerrar: editar perfil, términos de datos personales (Ley 1581), aliados válidos, categorías del aliado y el análisis regulatorio de pagos.

183 / 209

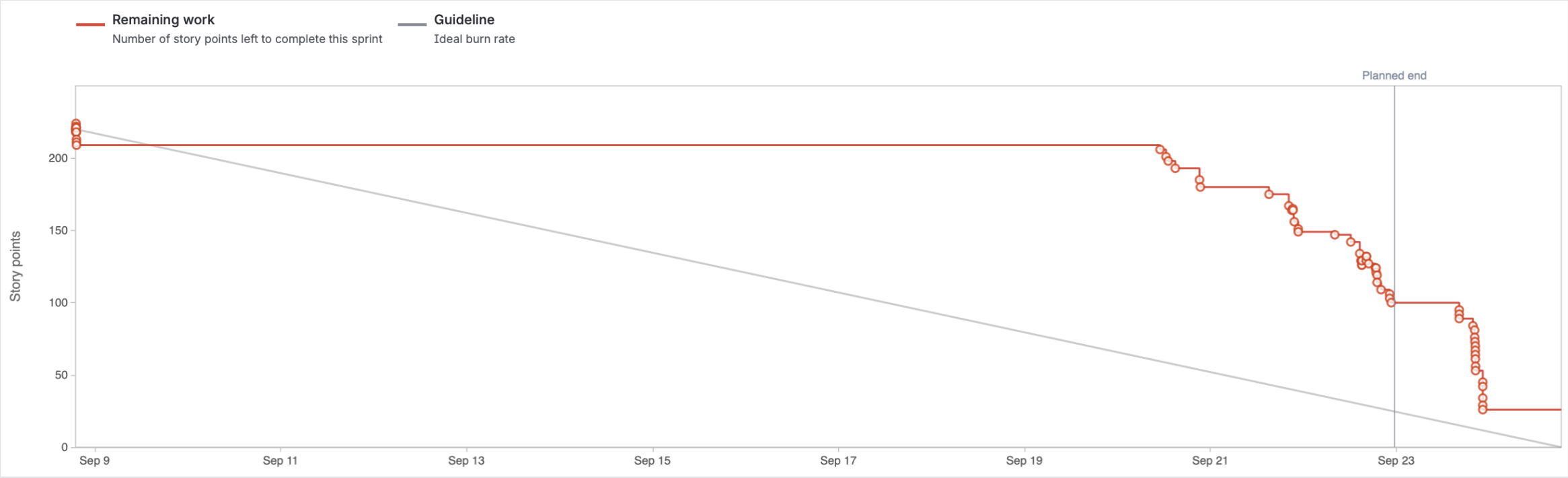
puntos completados (87,6 %)

12,4 %

carry-over en puntos

Semáforo: **AMARILLO** · carry-over entre 10 % y 25 % (Gobierno del Equipo §1.4.6)

Burndown: el sprint se quemó en sus últimos cuatro días



12 días

con la línea plana en 209 SP: el primer punto se quema el 20 de septiembre

≈ 100 SP

pendientes en el fin planeado del sprint (22 de septiembre, línea vertical)

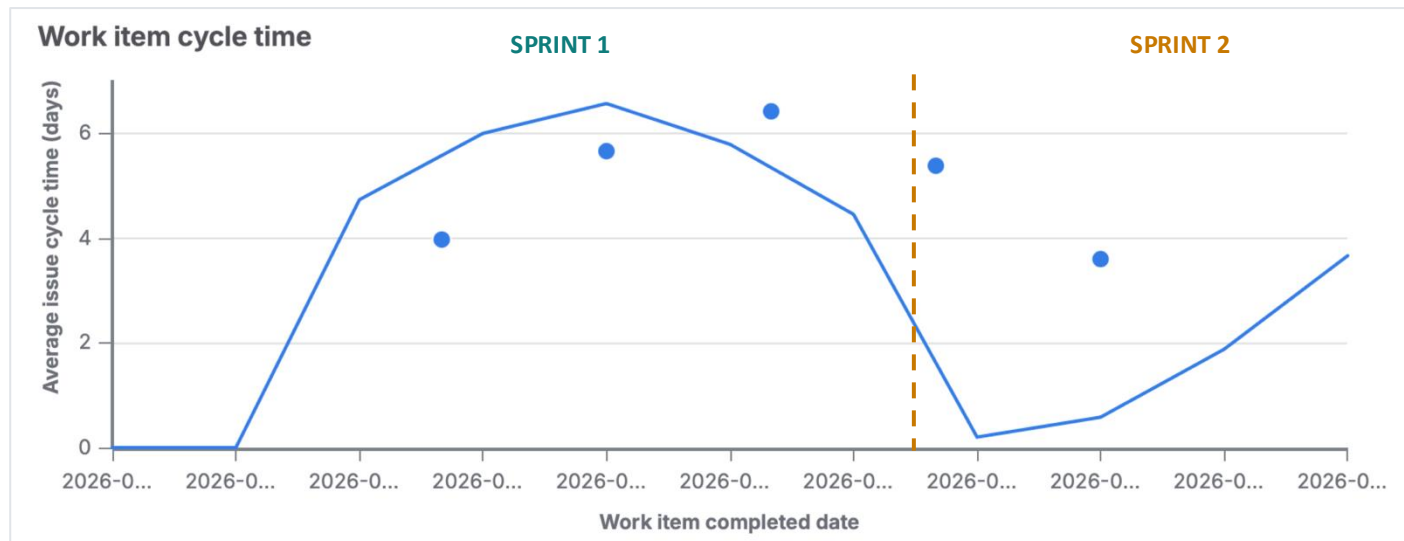
≈ 74 SP

cerrados el 23 de septiembre, después del fin planeado

≈ 26 SP

sin cerrar al final: carry-over de 12,4 % que pasa al Sprint 3

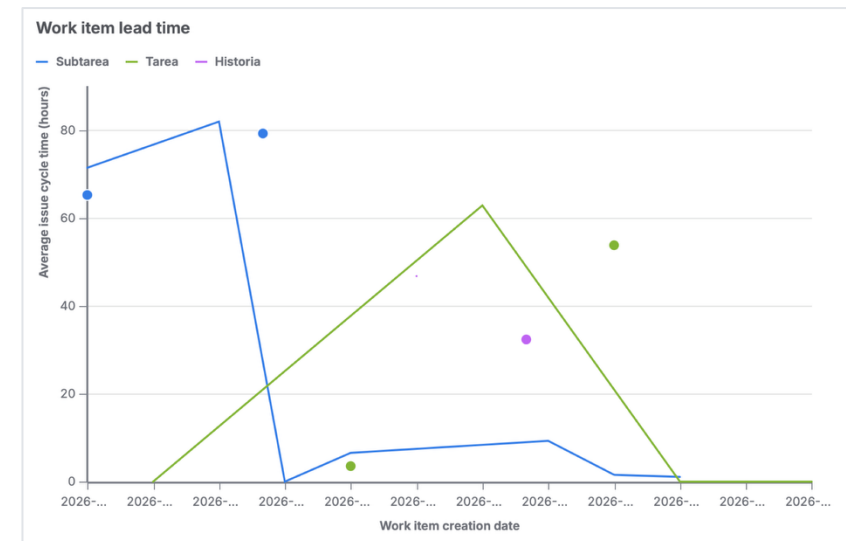
Cycle time y lead time: el cierre en bloque distorsiona la lectura



Eje X: 25, 28, 30 y 31 ago · 1, 2 y 3 sep | 20, 21, 22 y 23 sep

Cycle time (In Progress → Done)

- Sprint 1: entre 4,4 y 6,6 días por día de cierre. Sprint 2: entre 0,2 y 3,9 días.
- El Sprint 2 solo registra cierres del 20 al 23 de septiembre: las tarjetas pasaron a In Progress y a Done en los mismos días.
- El p85 aproximado baja de 6,2 a 3,0 días, pero **no es una mejora real** y no se usa para valorar.

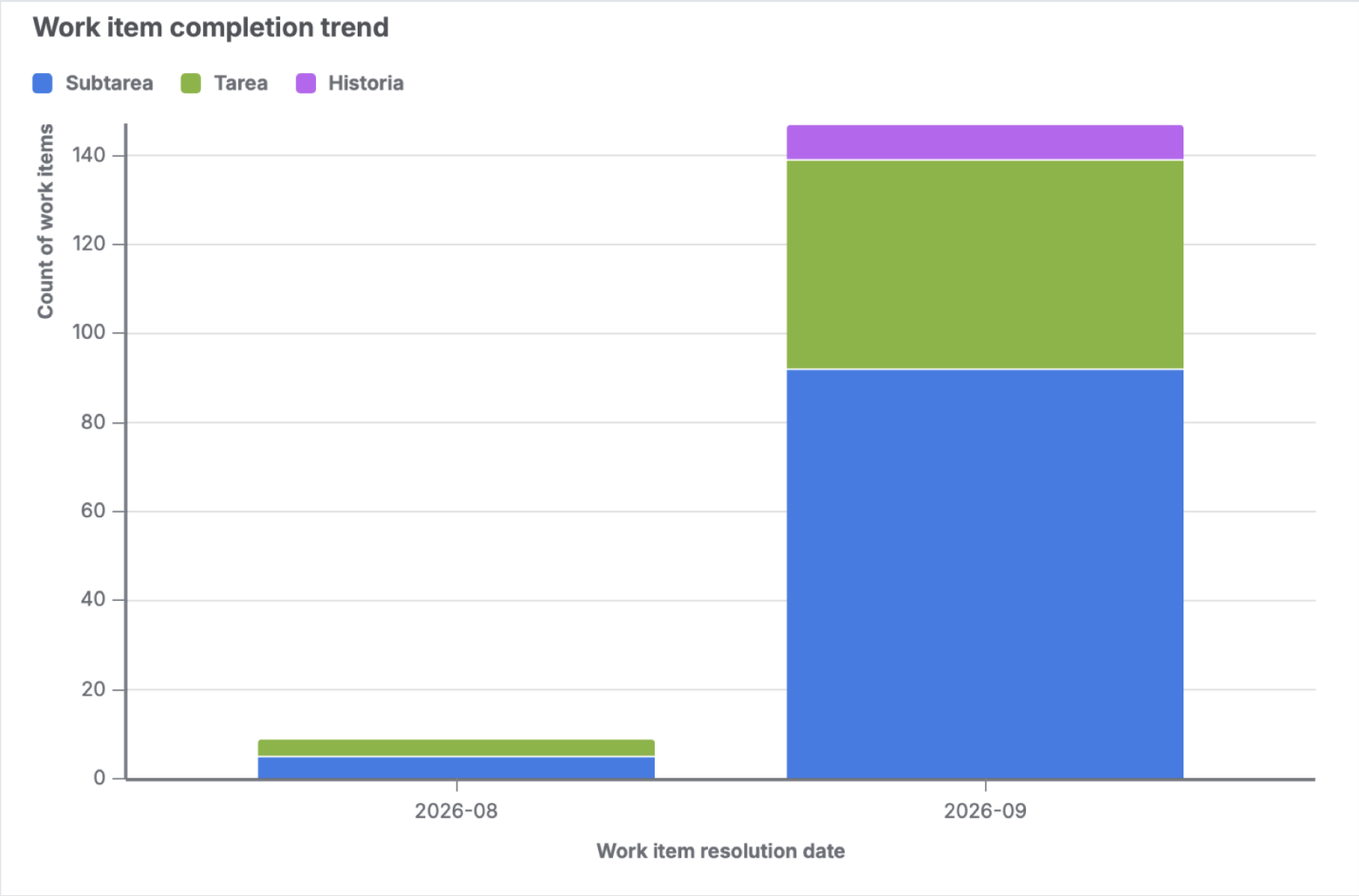


Eje X: fecha de creación (24 ago – 23 sep) · Eje Y: horas

Lead time (creación → cierre)

- HU y tareas con puntos: 14,3 días en promedio, casi todo el sprint.
- Subtareas creadas el 20 y 21 sep se cerraron en 1 a 2 horas: se registraron después de hacer el trabajo.

Completitud: las primeras historias del proyecto, cerradas al final



Reporte mensual de Jira: septiembre mezcla los cierres del Sprint 1 (1 al 3 sep) con los del Sprint 2.

8

historias de usuario
cerradas (Sprint 1: 0)

106

ítems resueltos, todos
desde el 20 de
septiembre

1,30

ítems creados por cada
ítem resuelto: el tablero
crece

34 de 93

subtareas sin
responsable asignado

Lectura: el equipo entregó valor funcional por primera vez, pero Jira no refleja el trabajo mientras ocurre. Sin movimiento diario, el burndown, el cycle time y el CFD pierden validez como evidencia.



Compromisos de flujo para el Sprint 3

Acción	Responsable	Cómo se verifica	Hoy
Mover cada tarjeta el día en que cambia el trabajo; ningún cierre en bloque	Scrum Master	Cierres en los últimos 4 días ≤ 40 %	100 %
Asignar responsable a cada subtarea al crearla	Scrum Master	Subtareas sin responsable = 0	34 de 93
Usar las etiquetas Devuelto y Bloqueo	QA + Scrum Master	Retrabajo y bloqueos calculables en el informe	No medibles
Adjuntar evidencia de DoR/DoD a cada HU antes de cerrarla o promoverla	PO + QA	Aceptación del PO registrada en el 100 % de las HU	8 de 9 HU sin criterios
Revisar la carga en la Daily y alertar al día 4 si alguien no ha movido ítems	Scrum Master	Ningún integrante bajo 60 % de cumplimiento en SP	9 de 10 pendientes en 2 personas

Propuestas derivadas de los datos de Jira. Se validan y se asignan en la Retrospectiva; cada una tiene una meta que el informe del Sprint 3 puede medir.

Product Backlog V3 — Enablers, deuda y spikes

Enablers nuevos (propuestos)

- Migración 008: RLS versionada con rol
- Migración 010: promover hook, bucket KYC y RPC
- Esqueletos: Gateway · Core · Despacho .NET · Reglas Java
- Cliente HTTP Flutter · rulesets · Kustomize · Newman + ZAP en CI · GHCR dev/staging

Deuda registrada

- SCRUM-1051 Políticas RLS sin versionar — **Crítica**
- SCRUM-1054 Índices de cobertura — Alta
- SCRUM-1055 Criterios y evidencia — Alta
- SCRUM-1056 Revisión por pares — Alta
- SCRUM-1058 Migración 004 en DEV — Media

Spikes de trade-offs

11 spikes · 57 h · primero SP-TO-06, 03, 01 y 05 (24 h)

Propuesta de Sprint 3

"Cerrar el aislamiento en el esquema versionado y levantar el primer recorrido vertical detrás del gateway."

1. Migración 008 con rol + H-02
2. Índices + promover las PoC a migraciones
3. Criterios de aceptación y revisión por pares
4. Spikes SP-TO-06 y SP-TO-03
5. Gateway + Core + cliente HTTP
6. Despacho .NET y aceptación real
7. US-04.1.2 aliados válidos (paginado)
8. Gates automáticos: rulesets, Newman, ZAP

Capacidad y compromiso final: se definen en el Sprint Planning.



TRAMA

La estructura detrás del servicio.